

Android Basics



Android Application Security



2. Android Basics



3. Android Penetration Testing Basics



4. Reverse Engineering



5. Android Application Attack Surface



Android Hacking Labs



Certified Android Pen Tester Exam (CAPT)



Mobile Hacking Lab - courses

- Application Security & Mobile hacking
- Userland fuzzing & exploitation
- Kernel fuzzing & exploitation



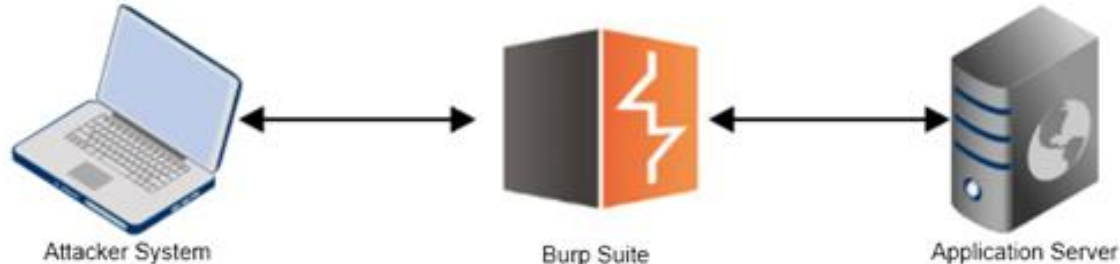
2. Android Basics

- Linux Kernel
- HAL (hardware abstraction layer)
- Libraries
- Android Runtime
- Android Framework
- Applications



3. Android Penetration testing basics

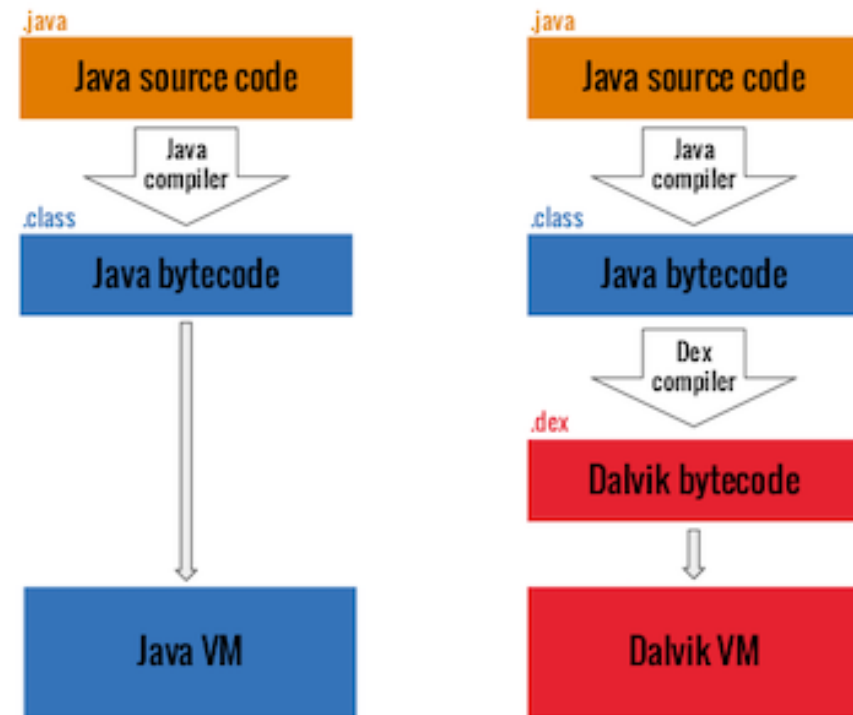
- Host software setup
- Android testing lab setup
- Intercepting network traffic
- Reverse engineering
- Dynamic instrumentation
- OWASP MAS



FRIDA
DYNAMIC INSTRUMENTATION TOOLKIT

4. Reverse engineering

- Understand the application architecture (Dalvik VM, DEX, Kotlin, Java, etc)
- Decompile an Android App (APK / AAB)
- Use tools like apktool and JADX



5. Application Attack Surface

- IPC - android:exported (activities, services, broadcast receivers)
- Data storage
- Platform issues (deep links, web views)
- Code issues (SQL injection, custom code)



Android Application Security



Android Architecture



Android Security



Android Application Structure



Android Application Publishing



Android Application Attack Surface

Introduction



Android Architecture



Android Security



Android Application Structure



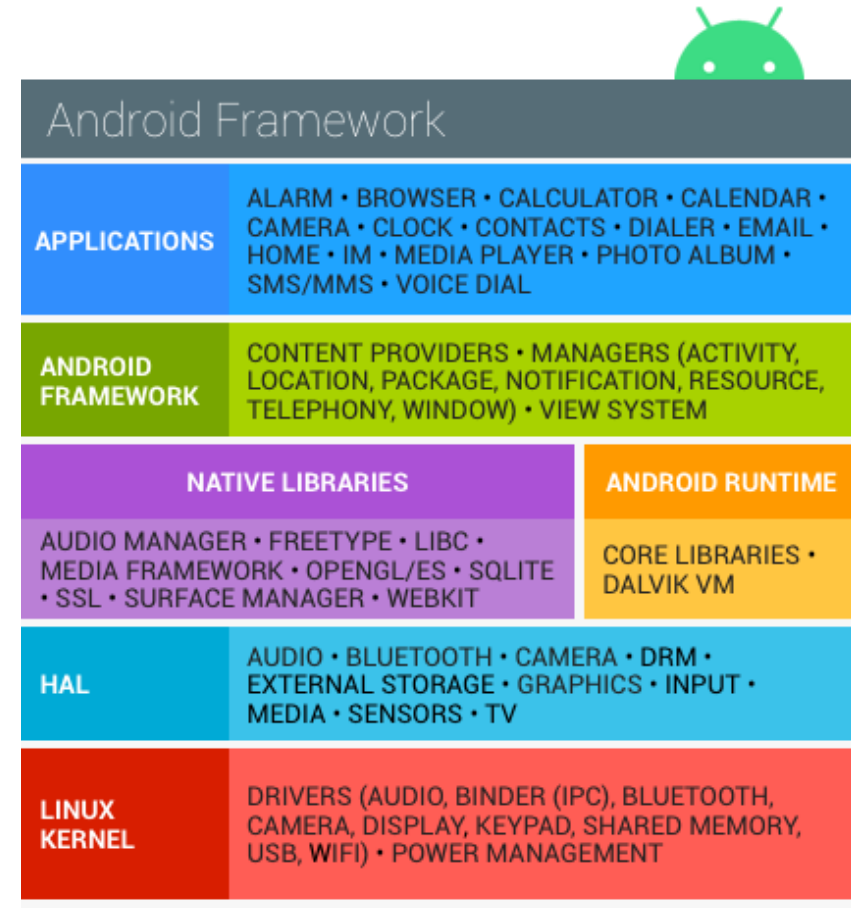
Android Application Publishing



Android Application Attack Surface

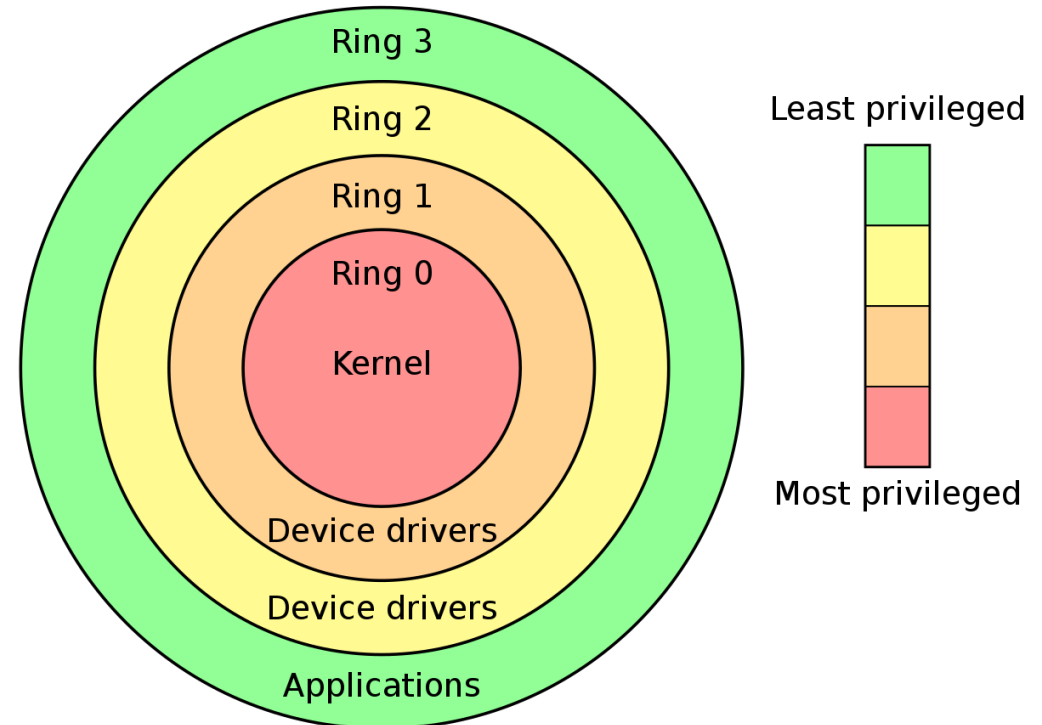
Android Architecture

- The main components of the Android architecture are:
 - Linux Kernel
 - HAL (hardware abstraction layer)
 - Libraries
 - Android Runtime
 - Android Framework
 - Applications



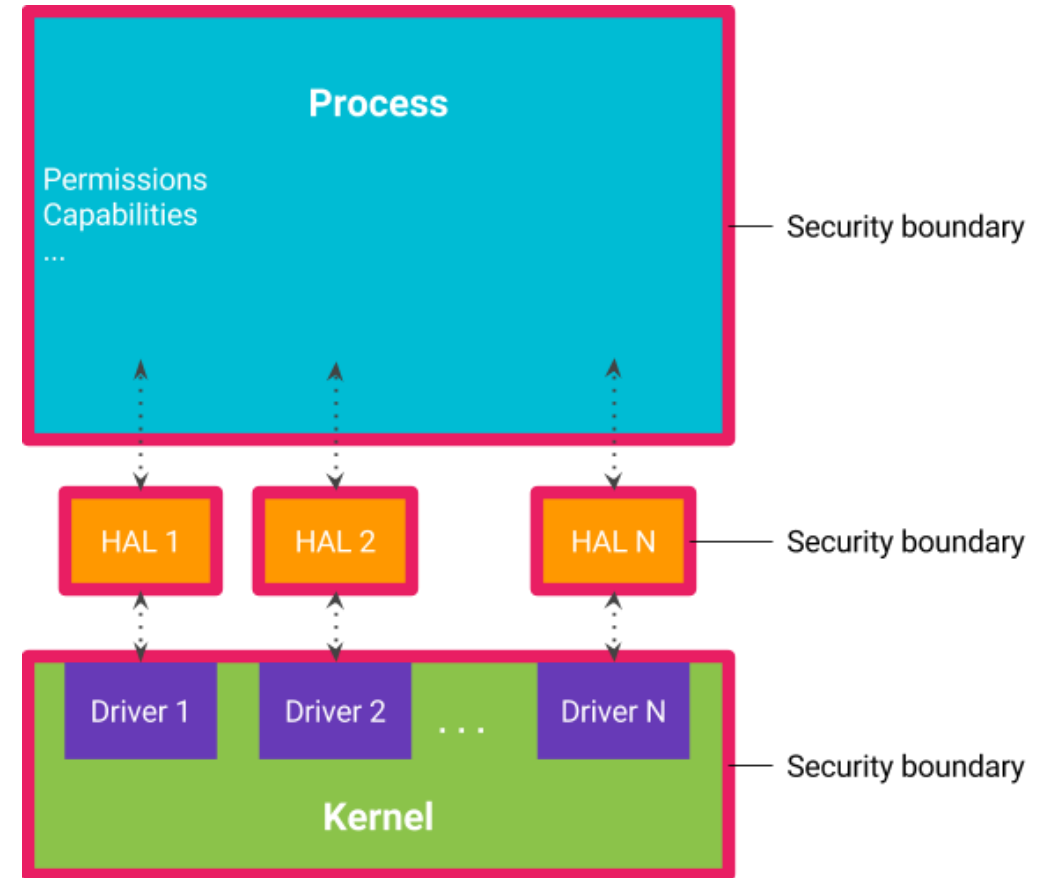
Android Architecture

- Linux Kernel
 - basic system services
 - memory management
 - process management
 - network stack
 - device drivers
 - Linux kernel vulnerabilities are possible
 - [exploit-db](#)
 - SELinux can reduce the impact



Android Architecture

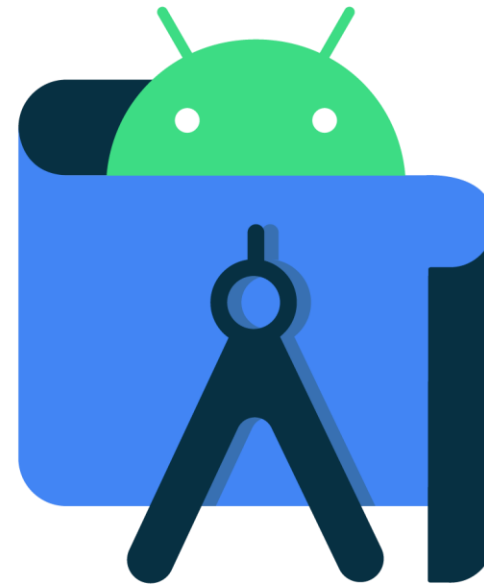
- HAL
 - Hardware Abstraction Layer
 - Software hooks (interfaces) between hardware and Android platform
- Vulnerabilities
 - <https://research.checkpoint.com/2021/looking-for-vulnerabilities-in-mediatek-audio-dsp/>



source: <https://android-developers.googleblog.com/2017/07/shut-hal-up.html>

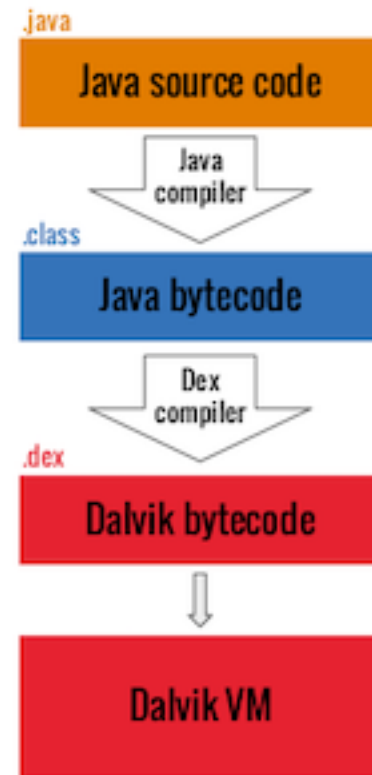
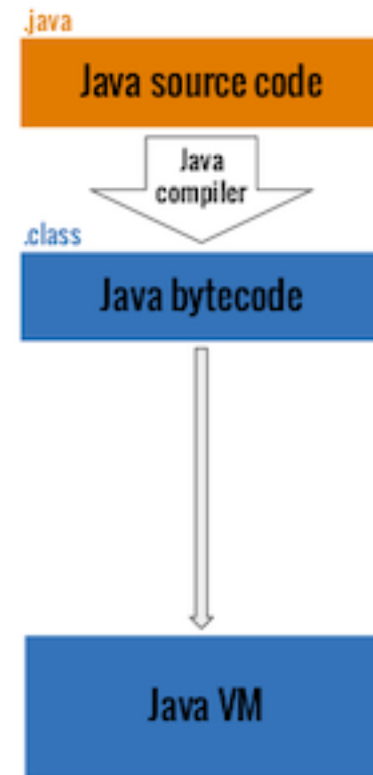
Android Architecture

- Libraries
 - C/C++ libraries that provide essential system services
 - SQLite for database management
 - OpenSSL for encryption
 - WebKit for web browsing.
- Example vulnerabilities:
 - <https://thehackernews.com/2022/10/22-year-old-vulnerability-reported-in.html>
 - SQL injection



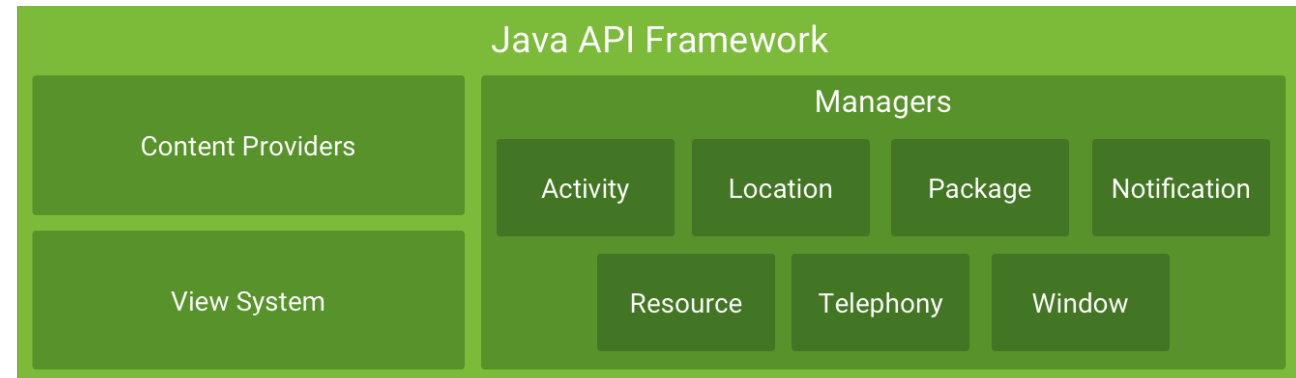
Android Architecture

- Android Runtime
 - Dalvik Virtual Machine (DVM),
 - executes Dalvik bytecode
 - Android Runtime (ART)
 - executes Android application package (APK) files.
 - ahead-of-time (AOT) compilation improves application performance and reduce memory usage.
 - Vulnerabilities
 - [CVE-2017-13156](#)



Android Architecture

- Android Framework
 - high-level APIs for developers
- Components such as:
 - activities, services, broadcast receivers, and content providers.
- Create and manage the user interface, handle user input, and access device features.



Android Architecture

- Applications
 - topmost layer of the Android architecture
 - Java or Kotlin
 - packaged as APK files, which contain the application code, resources, and manifest file.



Android Security

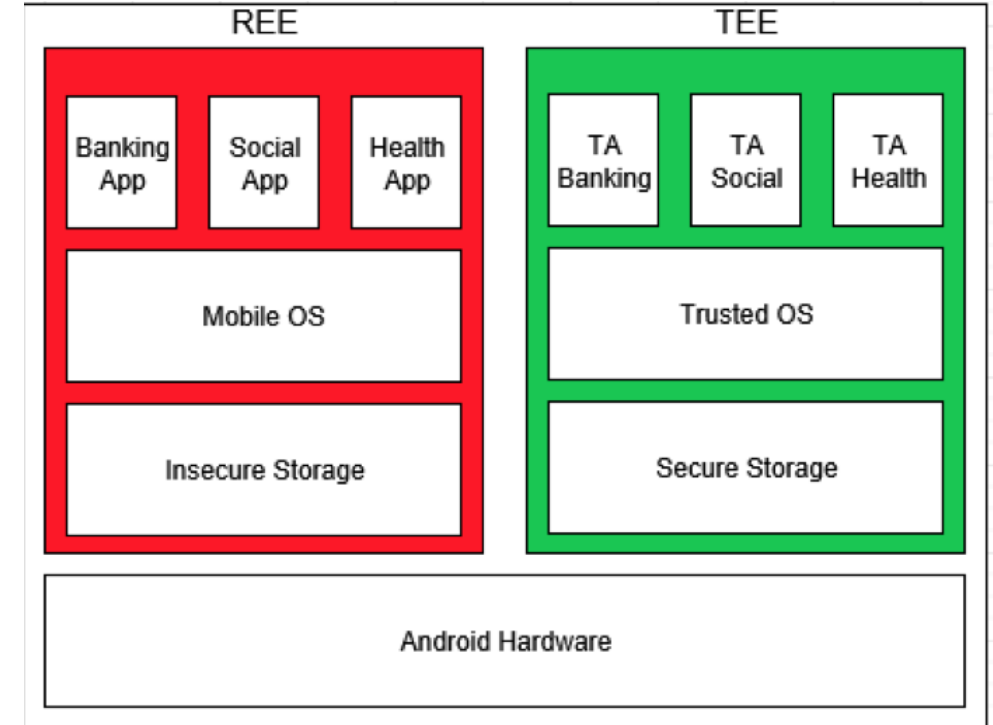
- System security
- Network security
- Software isolation
- Anti-exploitation



Android Security

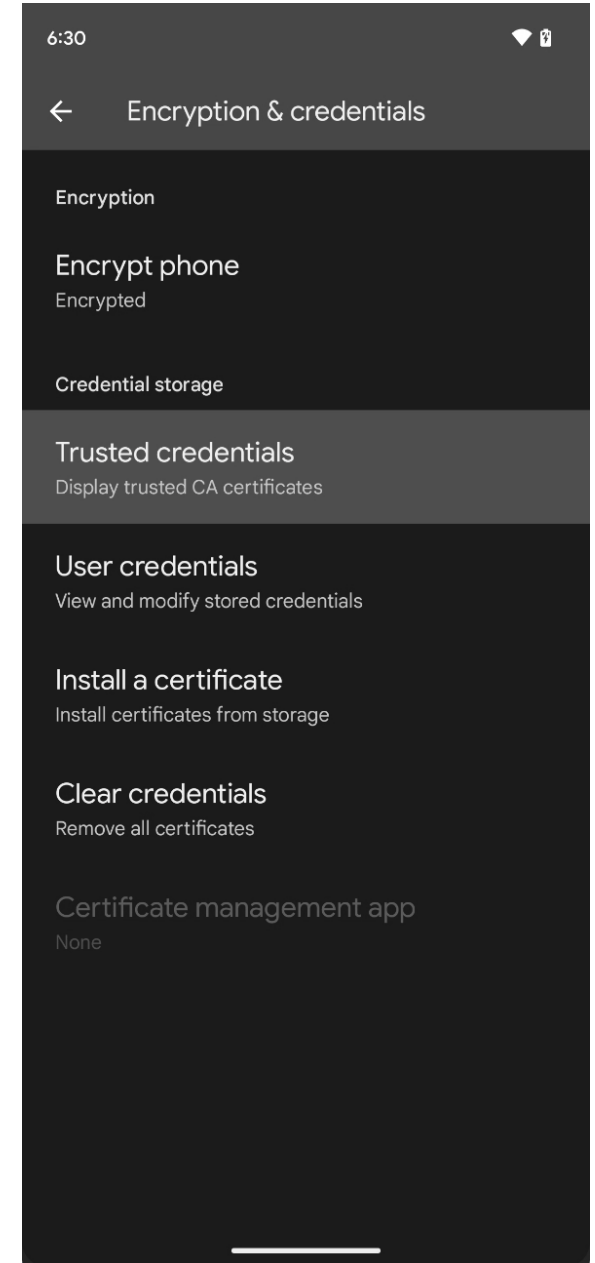
- System security
 - Device encryption
 - File-based for Android 7+
 - Full-disk for Android 5+
 - Trusted Execution Environment (TEE)
 - Hardware
 - Keystore to store for example cryptographic keys and biometrics
 - Software
 - Trusted applications and API's
 - Verified boot

Verified Boot strives to ensure all executed code comes from a trusted source



Android Security

- Network security
 - TLS by default and DNS over TLS since Android 9
 - Separate network security config per app
 - Certificate pinning



Android Security

- Software isolation
 - Android uses SELinux (Security-Enhanced Linux) to enforce mandatory access control (MAC) and isolate apps in sandboxes.
 - Permissions are declared per app in the manifest file



Allow **Twitter**
to access your
contacts?

DENY

ALLOW

Android Security

- Anti-Exploitation

Android has different protections against (kernel) exploits / buffer overflows:

- ASLR; Address Space Layout Randomization, since android 4.1
- KASLR, kernel, since android 8
- DEP; Data Execution Prevention (DEP)
- SECCOMP filter, to secure syscalls



Android Application Structure

- API's
- Sandbox
- Packaging
- Manifest file
- App components
- IPC



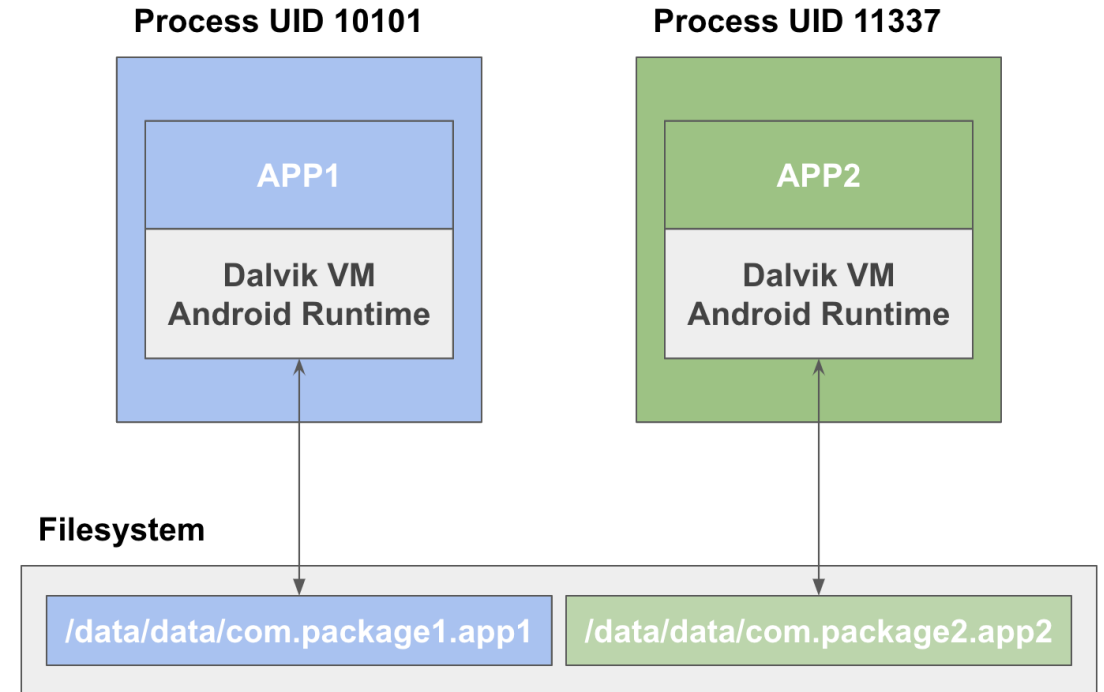
Android Application Structure

- API's
 - Reach hardware / OS components via the NDK in C/C++
 - Java API's via the SDK



Android Application Structure

- Sandbox
 - VM per app
 - Directory and user per app
 - `/data/data/com.mobilehackinglab.app`
 - Can be shared via `sharedUserId`



Android Application Structure

- Packaging
 - APK; Android Package Kit
 - AAB; Android App Bundle

▼  app-release.aab

▼  base

▼  manifest

 AndroidManifest.xml

▶  lib

▶  root

▶  dex

▶  res

▶  assets

 assets.pb

 native.pb

 resources.pb

▶  META-INF

▶  BUNDLE-METADATA

 BundleConfig.pb

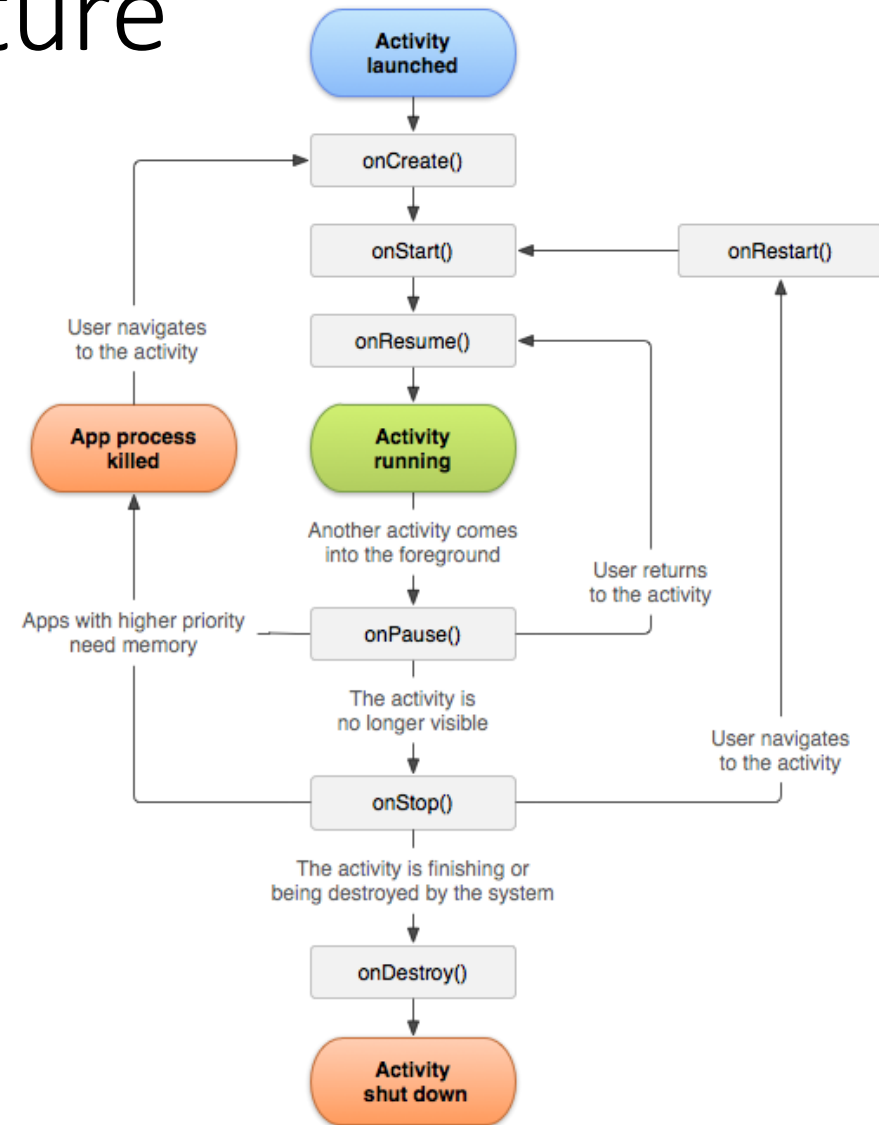
Android Application Structure

- Manifest file
 - AndroidManifest.xml
 - App components
 - Permissions
 - Flags

```
<uses-permission android:name="android.permission.INTERNET" />
<uses-permission android:name="android.permission.CHANGE_WIFI_MULTICAST_STATE" />
<uses-permission android:name="android.permission.VIBRATE" />
<uses-permission android:name="android.permission.ACCESS_FINE_LOCATION" />
<uses-permission android:name="android.permission.ACCESS_COARSE_LOCATION" />
<uses-feature android:name="android.hardware.location.gps" android:required="false" />
<uses-feature android:name="android.hardware.location" android:required="false" />
```

Android Application Structure

- App components
 - Activities
 - Services
 - Broadcast receivers
 - Content providers

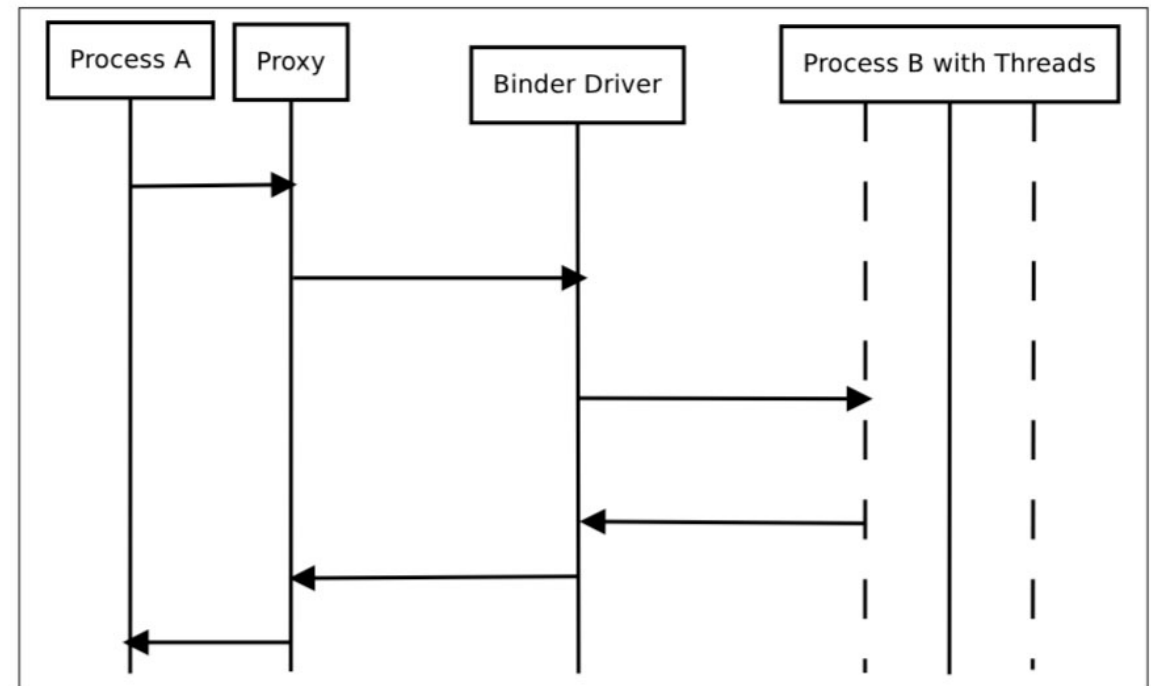


Android Application Structure

- IPC

Inter-Process Communication

- Secure way to transfer data between apps / sandboxes
- Middleware using Binder framework
- Intents



Android Application Publishing

Android Application Publishing

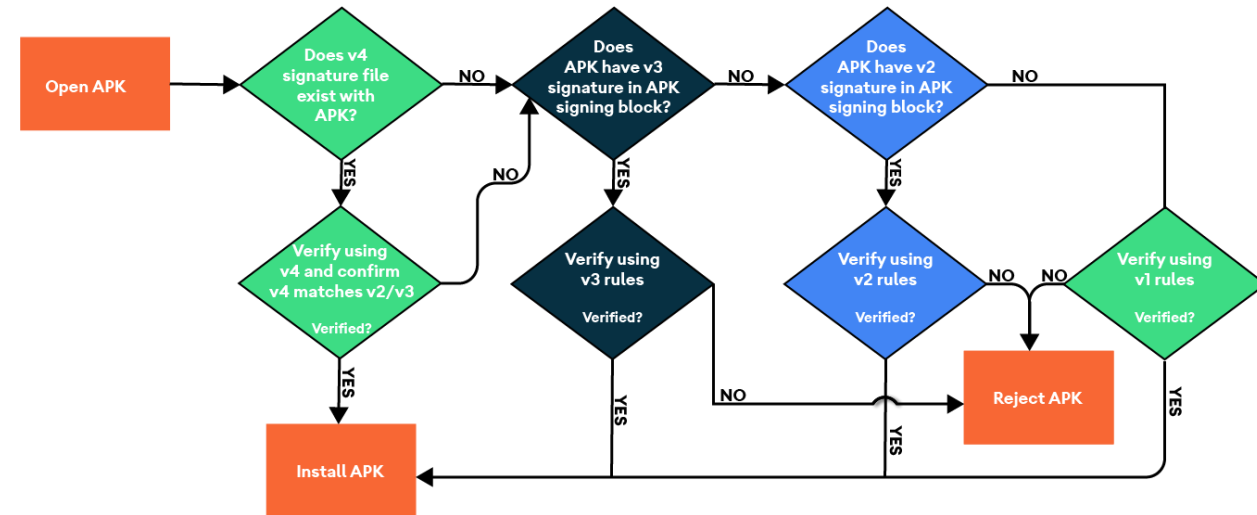
- Signing apps
- Publishing apps



Google Play

Android Application Publishing

- Signing apps
 - Sign with certificate /dev public key
 - Self-signed for debugging
 - Valid developer key for play store
 - Different signing schemes (v1-4)



Android Application Publishing

- Publishing apps
 - Google Play Store
 - Alternatives like Amazon AppStore
 - Don't publish, only give a download link to your apk

